

Web Application Security Assessment

OPERATION SECURE JUICE

G-606 • SRMCEM Cybersecurity Bootcamp 2026 • Summer Training Program

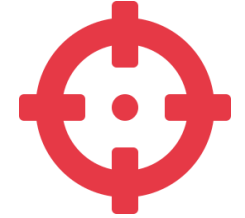
CLIENT	OWASP Juice Shop
ASSESSOR	Mr. Romaer Ahuja — Cybersecurity Trainer
SECURITY ANALYST	Vaishali Srivastava — CSE (Cyber Security)
IDENTIFIERS	Campus ID RE23CY033 • Roll No. 2301221720034

18

SECURITY RISKS IDENTIFIED

4 Critical • 7 High • 7 Medium

Purpose of the Assessment



Evaluate the security posture of the OWASP Juice Shop web application by identifying vulnerabilities, security misconfigurations, and weaknesses that could be exploited by attackers.



Modern Vulnerable App

One of the most sophisticated intentionally-insecure apps — used for training, demos, and CTFs.



OWASP Top Ten Coverage

Encompasses vulnerabilities from the entire OWASP Top Ten plus real-world security flaws.



Graded Challenges

Hacking challenges of varying difficulty, tracked on a hidden score board.



Tooling Benchmark

Used by scanners & proxies to test handling of JS-heavy frontends and REST APIs.

Scope of the Assessment

An intentionally insecure web application used for educational and training purposes — the following components were included:



Application Endpoint

Mapping the live demo environment



Score Board Discovery

Locating hidden hacking-challenge tracker



OSINT Gathering

Key vulnerabilities & technology stack



Attack Surface Mapping

Identifying all entry points



Vulnerability Exploitation

Using Damn Vulnerable Web App techniques



Access Control Review

Authentication & authorization checks



OWASP Risk Mapping

Mapping findings to OWASP Top 10 2021



Risk Register

Likelihood x impact scoring of all risks

Application & User Base



Purpose

The target application is an open-source, intentionally insecure platform. It simulates a modern e-commerce store and is widely used for security awareness training, developer education, and penetration testing practice.

VISIT

demo.owasp-juice.shop

Hosted by the non-profit Open Worldwide Application Security Project (OWASP); developed and maintained entirely by volunteers as an awareness, training, and exercise tool for security risks in modern web apps.

[Home](#) • [About Us](#) • [Photo Wall](#) • [Score Board](#) • [Login](#)



Security Learners & Students

Learning ethical hacking, VAPT, or preparing for CEH, OSCP, eWPT certifications.



Developers

Understanding how XSS, SQLi, and broken auth appear in real-world code to avoid them in production.



Security Trainers & Organizations

Companies and universities run workshops, red-team exercises, and training programs.

Technology Profile & OSINT

TECH STACK (via Wappalyzer)

JavaScript Framework	Zone.js, Angular
Font Script	Google Font API, Font Awesome
Programming Language	TypeScript, Node.js

TECHNOLOGY PROFILE (via builtwith.com)

Web Server	Apache 2.4
Server Name	Strato DNS
Firewall (wafw00f)	Fastly (Fastly CDN)

GOOGLE DORKING

<code>site:owasp-juice.shop</code>
Useful for attacker reconnaissance
<code>site:owasp-juice.shop filetype:pdf</code>
Surfaced an internal presentation deck
<code>site:owasp-juice.shop security</code>
Surfaced the security companion guide

Wappalyzer and builtwith.com both confirm a JavaScript-heavy Angular/Node.js stack — common ground for client-side and dependency-based vulnerabilities.

Technology Fingerprinting & WHOIS

Information gathered without directly interacting with the application — using Whatweb, ICANN lookup, and Nslookup.

81.169.145.156

IP SERVER

Heroku

HTTP SERVER

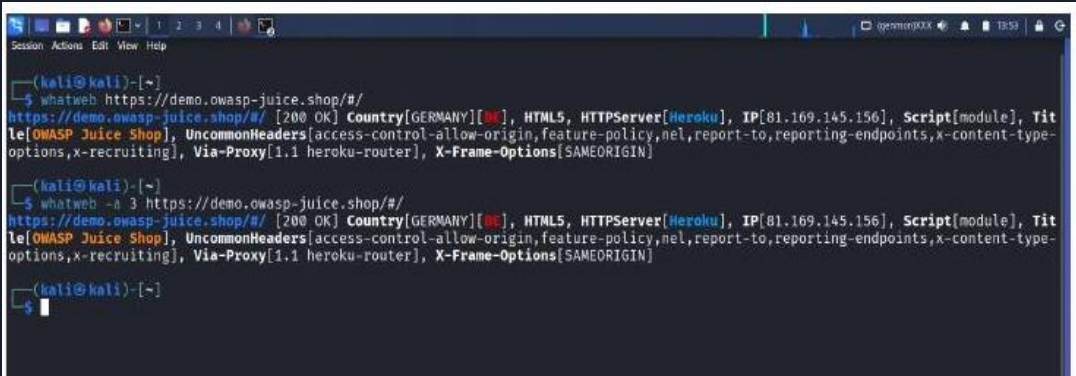
ICANN / WHOIS LOOKUP

Domain:	owasp-juice.shop	Registry ID:	DO2909101-GMO
Status:	Active	Nameservers:	docks10/shades01.rzone.de
Created:	2017-11-20	Expires:	2026-11-20

NSLOOKUP

IPv4 (A) : 81.169.145.156

IPv6 (AAAA) : 2a01:238:20a:202:1156::0



Whatweb fingerprinting output (Kali Linux)

Reconnaissance maps the attack surface and identifies entry points without alerting the target.

Port Scanning & Server Vulnerabilities

Nikto (Kali Linux) was used to identify vulnerabilities on the web server.



Server Banner Changed

From 'Heroku' to 'Apache/2.4.68 (Unix)' — a deliberate technology-disclosure mismatch.



BREACH Attack Exposure

Content-Encoding header set to 'deflate', which may indicate vulnerability to the BREACH attack.



Scan Anomalies

Scan terminated with 19 errors and 12 items reported on the remote host.

```
(kali@kali)-[~]
└─$ nikto -h https://demo.owasp-juice.shop/#/
- Nikto v2.6.0

+ Target IP: 81.169.145.156
+ Target Hostname: demo.owasp-juice.shop
+ Target Port: 443

+ SSL Info: Subject: /CN=*.owasp-juice.shop
            CN: *.owasp-juice.shop
            SAN: *.owasp-juice.shop, owasp-juice.shop
            Ciphers: TLS_AES_256_GCM_SHA384
            Issuer: /C=GB/O=Sectigo Limited/CN=Sectigo Public Server Authentication CA DV R36
+ Platform: Unknown
+ Start Time: 2026-06-23 14:55:08 (GMT-4)

+ Server: Heroku
+ Multiple IPs found: 81.169.145.156, 2a01:238:20a:202:1156::
+ ERROR: Failed to check for updates: 403
+ [999986] /: Retrieved via header: 1.1 heroku-router.
+ [999986] /: Retrieved access-control-allow-origin header: *.
+ [999100] /: Uncommon header(s) 'reporting-endpoints' found, with contents: heroku-nel="https://nel.heroku.com/reports?s=JMCVjxNA
YYLoFNZNEhpiwaG6OPuqBkuwIYD20vA28lguX3D8&id=812dcc77-0bd0-43b1-a5f1-b257503829596ts=1782240989".
+ [999100] /: Uncommon header(s) 'x-recruiting' found, with contents: /#/jobs.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999996] /robots.txt: contains 1 entry which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/R
obots.txt
+ [999962] /: Server banner changed from 'Heroku' to 'Apache/2.4.68 (Unix)'.
+ [999992] /: Server is using a wildcard certificate: *.owasp-juice.shop. See: https://en.wikipedia.org/wiki/Wildcard_certificate
+ [999966] /: The Content-Encoding header is set to "deflate" which may mean that the server is vulnerable to the BREACH attack. S
```

SSL Certificate & Port Discovery (Nmap)



Certificate Information

COMMON NAME (CN)

Sectigo Public Server Auth CA DV R36

ORGANIZATION (O)

Sectigo Limited

ISSUED ON

Sep 25, 2025, 5:30:00 AM

EXPIRES ON

Oct 17, 2026, 5:29:59 AM

PUBLIC KEY ALGORITHM

rsaEncryption (3072 bits)

CERTIFICATES ON RECORD (CRT.SH)

13 SSL/TLS certificates



Nmap Scan Result

Port 3000/TCP open running an unencrypted HTTP service powered by Node.js Express. No HTTPS on port 443 — complete absence of SSL/TLS encryption. The X-Powered-By: Express header confirms technology disclosure.

MAPS TO: OWASP A02 (Cryptographic Failures) • A05 (Security Misconfiguration)

```
kali@kali:~$ nmap localhost
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-23 16:11 -0400
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000000s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
3000/tcp  open  ppp

Nmap done: 1 IP address (1 host up) scanned in 0.10 seconds

kali@kali:~$ nmap -p 3000 localhost
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-23 16:11 -0400
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000000s latency).
Other addresses for localhost (not scanned): ::1
PORT      STATE SERVICE
3000/tcp  open  ppp

Nmap done: 1 IP address (1 host up) scanned in 0.10 seconds

kali@kali:~$ nmap -sV localhost
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-23 16:12 -0400
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000000s latency).
Other addresses for localhost (not scanned): ::1
If the Nmap version detection results for a target host are wrong (even just slightly), please notify us so that
```


Mapping the Application's Entry Points

Every place an attacker might interact with the application or its supporting infrastructure.

1	Home Page	Tech fingerprinting, info disclosure, clickjacking, reflected XSS	HIGH RISK
2	Login Page	Brute force, SQLi, auth bypass, session fixation, CSRF	HIGH RISK
3	Contact / Feedback Forms	Stored XSS, email header injection, CSRF, SSRF	HIGH RISK
4	Shopping Cart	Price tampering, IDOR, race conditions, business-logic abuse	HIGH RISK
5	About Us	OSINT harvesting, open redirect, clickjacking on embeds	LOW-MED

Why Identifying Entry Points Matters



Risk Prioritization

Knowing where users and systems interact with the application helps focus security testing on the most exposed components, rather than spreading effort evenly across low-value areas.



Defense Planning

Mapping entry points enables appropriate controls — authentication, input validation, rate limiting, and monitoring — to be applied precisely where they are needed most.

5 entry points mapped → 29 distinct attack vectors → 18 confirmed security risks

Findings Mapped to OWASP Top 10 (2021)

Each attack identified during reconnaissance is classified against its corresponding OWASP Top 10 category.

ENTRY POINT	ATTACK	OWASP CATEGORY	LIKELIHOOD
Home Page	Technology Fingerprinting	A05:2021 — Security Misconfiguration	Medium
Login Page	Username Enumeration	A01:2021 — Broken Access Control	Medium
Contact / Feedback	CSRF	A01:2021 — Broken Access Control	Medium
Shopping Cart	Coupon Code Brute Force	A04:2021 — Insecure Design	Medium
About Us	OSINT / Info Harvesting	A05:2021 — Security Misconfiguration	Medium
About Us	Open Redirect via External Links	A01:2021 — Broken Access Control	Medium

7 medium-risk entries identified across 5 entry points — all map to A01, A04, or A05 of OWASP Top 10 2021.

Critical-Risk Findings

The four highest-severity risks, scored by likelihood x impact.



4 Critical risks could result in unauthorized access, data breaches, financial fraud, or compromise of backend systems.

High & Medium-Risk Findings

ID	ENTRY POINT	THREAT	SCORE	LEVEL
RR-05	Shopping Cart	IDOR on Saved Cart	16	High
RR-06	Login Page	Session Fixation	12	High
RR-07	Contact Forms	Stored XSS	12	High
RR-08	Contact Forms	Email Header Injection	12	High
RR-09	Home Page	Reflected XSS via URL Params	12	High
RR-12	Home Page	Technology Fingerprinting	12	Medium
RR-14	Login Page	Username Enumeration	12	Medium

FULL REGISTER

4

CRITICAL

7

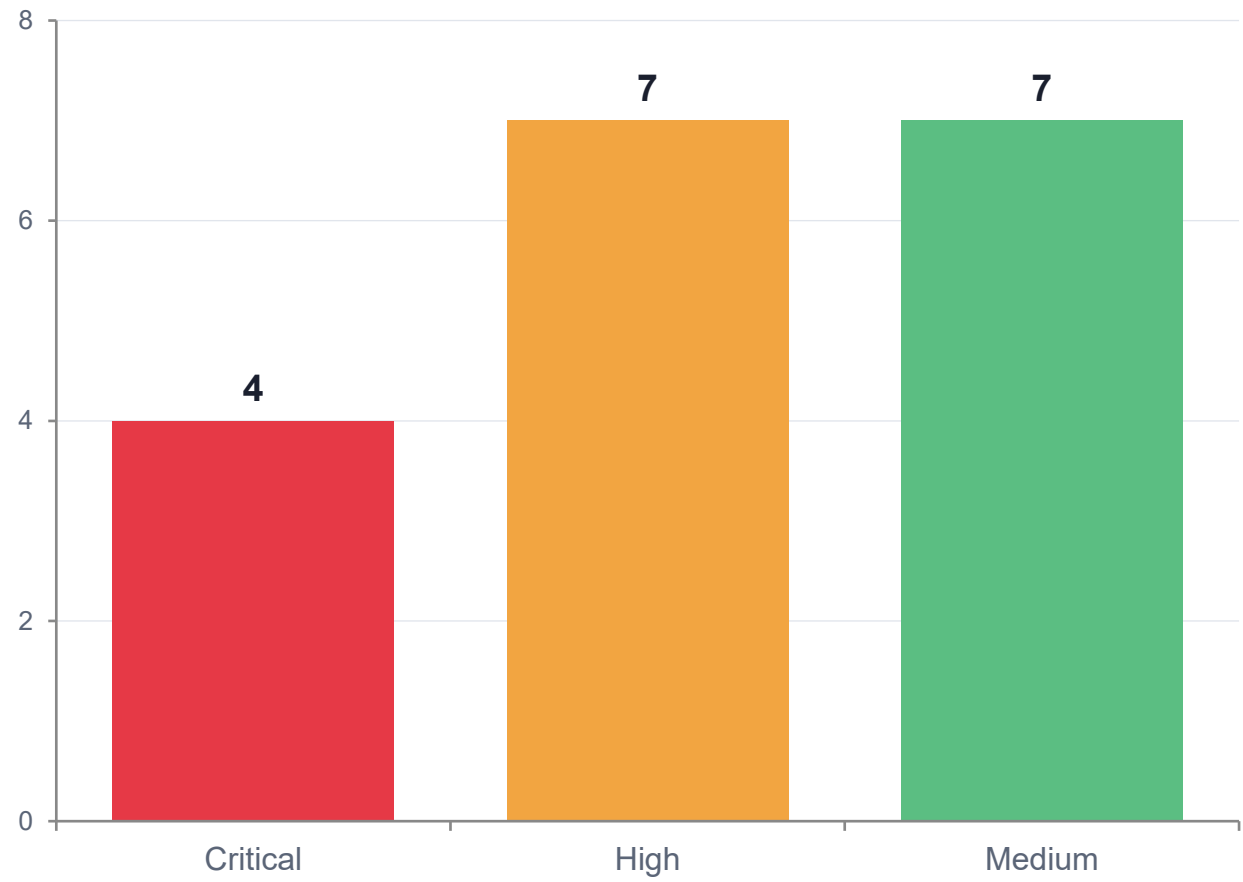
HIGH

7

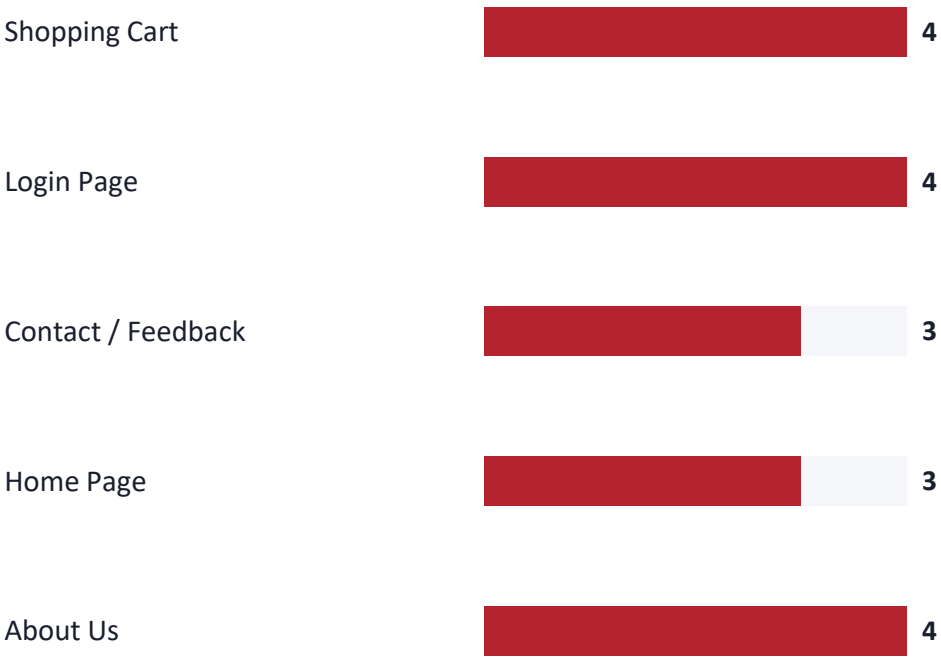
MEDIUM

18 risks total, all currently OPEN

Risk Distribution at a Glance



RISKS BY ENTRY POINT



All 5 entry points carry between 3 and 4 open risks — exposure is broad, not concentrated in one area.

RECOMMENDATIONS

Immediate Actions

Prioritized mitigations mapped directly to the highest-impact findings.



Brute Force / Credential Stuffing

Implement MFA, account lockout, rate limiting, CAPTCHA, IP reputation filtering, password breach detection.



SQL Injection

Use parameterized queries, prepared statements, ORM protections, input validation, WAF rules, secure code review.



IDOR on Saved Cart

Implement object-level authorization checks on every request.



Session Fixation

Regenerate session IDs after authentication and privilege changes.



Reflected XSS

Apply context-aware output encoding and a Content Security Policy (CSP).



Technology Fingerprinting

Remove version banners and minimize information disclosure.



OSINT / Info Harvesting

Review publicly exposed information and metadata.

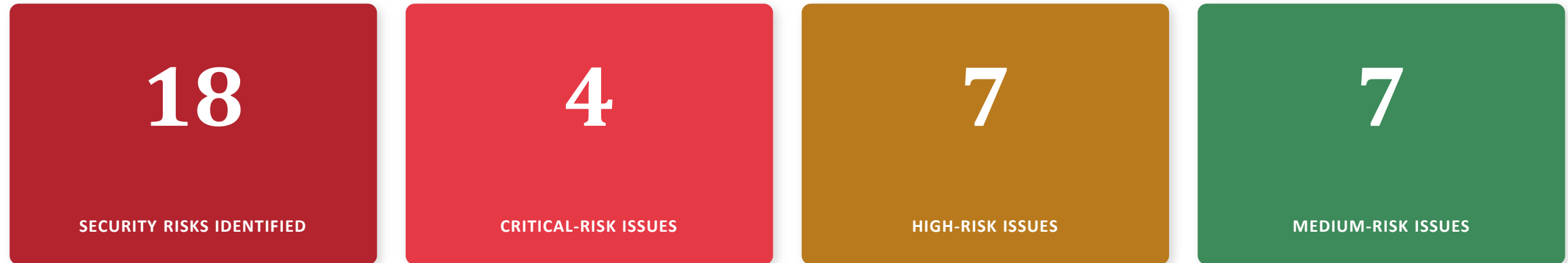


Coupon Brute Force

Apply rate limiting, increase coupon complexity, add monitoring.

CONCLUSION

Assessment Outcomes at a Glance



Most significant risks:

Brute Force / Credential Stuffing • SQL Injection • Price / Quantity Tampering • SSRF

— *each capable of causing unauthorized access, data breaches, financial fraud, or backend compromise.*

Also notable:

IDOR • XSS • Session Fixation • CSRF • Race Conditions — underscoring the need for robust access controls, secure session handling, and comprehensive input validation.

CONCLUSION

Securing the Juice — What This Project Showed

This project conducted a full security assessment and risk analysis of the intentionally vulnerable OWASP Juice Shop application, following a structured risk-management approach to identify, evaluate, and prioritize vulnerabilities by likelihood and business impact.

It reinforced the importance of integrating security into every stage of the software development lifecycle and adopting a proactive approach to vulnerability management.



Structured Methodology

Recon, attack-surface mapping, and risk scoring applied end-to-end.



Stronger Security Posture

Addressing findings reduces the likelihood of successful attacks.



Continuous Practice

Regular assessments build long-term resilience, not one-time fixes.



Thank You

Questions & Discussion

Vaishali Srivastava

CSE (Cyber Security) • Campus ID BE23CY033

SRMCEM Cybersecurity Bootcamp 2026